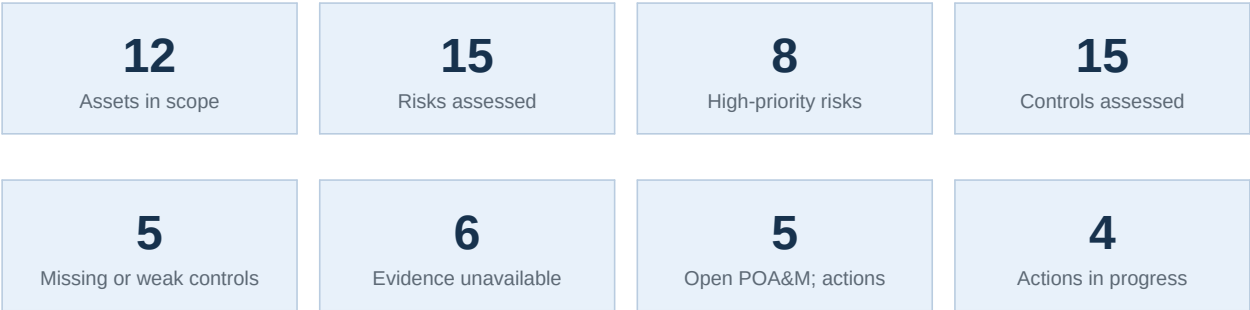


IT GRC Risk & Control Assessment

Executive portfolio summary | Assessment cut-off: 13 July 2026

A synthetic, evidence-led case study that connects assets, risks, controls, assessment findings, remediation actions, and management reporting for an internal academic services system.



Executive conclusion

Theme	Evidence-based conclusion
Access governance	The highest residual risk is privileged access management (R-001, residual score 15). Quarterly recertification evidence is incomplete.
Detection and resilience	Admin log review, vulnerability tracking, and restore-test evidence are missing or insufficiently documented.
Audit readiness	Nine evidence sets are partial and six are unavailable. No control is presented as fully evidenced in the baseline.
Remediation	Fifteen POA&M actions define owners, target dates, evidence requirements, dependencies, and closure criteria.

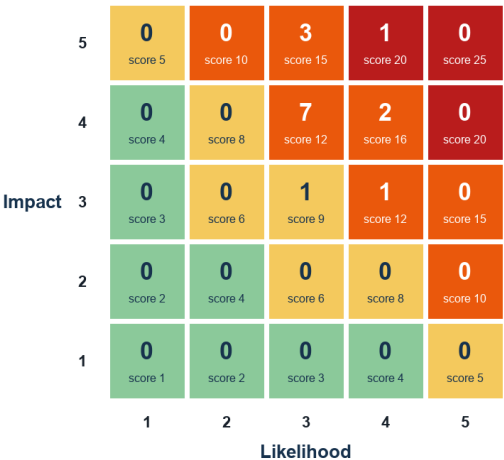
Scope boundary

This is a self-directed portfolio exercise using synthetic data. It is not a real company engagement, legal opinion, ISO/IEC 27001 certification audit, COBIT capability assessment, or claim of operating control effectiveness.

Risk and control posture

Inherent Risk Heatmap

15 synthetic risks plotted by likelihood and impact



Portfolio snapshot

High-priority risks: 8

Medium-priority risks: 7

No Low-rated risks

Highest residual risks

Risk	Area	Inherent	Residual	Priority
R-001	Access Management	20	15	High
R-002	Data Privacy	15	12	High
R-003	Backup & Recovery	15	12	High
R-004	Change Management	16	12	High
R-009	Business Continuity	15	12	High
R-010	User Lifecycle Management	16	12	High
R-013	Data Retention	12	12	High

Control Implementation Status

15 controls assessed across governance, security, resilience, and operations

Implementation status



Key message: no control is represented as fully implemented in this simulated baseline.

Remediation and evidence readiness

Remediation Portfolio

15 POA&M actions with explicit owners, target dates, evidence, and closure criteria



Assessment cut-off: 13 July 2026. Dates and owners are simulated for portfolio demonstration.

High-priority remediation portfolio

POA&M	Control area	Target	Status	Owner
P-001	Access Management	2026-07-31	Open	IT Manager / System Owner
P-002	Access Management / User Lifecycle	2026-08-07	Open	IT Admin / HR Coordinator / Data Owner
P-003	Logging & Monitoring	2026-08-14	Open	IT Security / System Administrator
P-004	Backup & Recovery	2026-08-21	In Progress	IT Operations Lead
P-005	Change Management	2026-08-28	In Progress	System Owner / Change Manager
P-008	Data Retention / Privacy	2026-08-21	Open	Data Owner / Compliance Coordinator
P-013	Vulnerability Management	2026-08-28	Open	IT Security / Vendor Manager

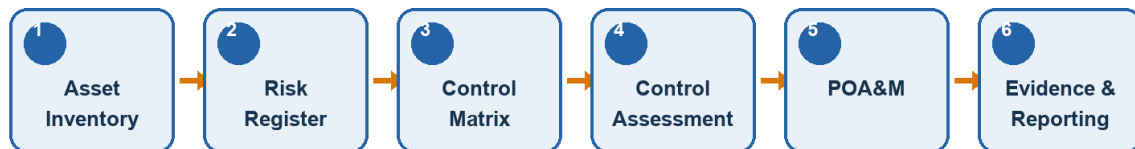
Evidence interpretation

The evidence tracker contains 15 rows: 9 partial and 6 unavailable. The repository records required evidence and remediation ownership but deliberately does not fabricate evidence files or successful review dates.

Methodology, traceability, and sources

IT GRC Assessment Workflow

Synthetic portfolio case study - evidence-based traceability from assets to management reporting



Traceability rule

Every remediation and evidence-tracker row links back to a control, assessment finding, risk, and asset context.

Assessment approach

- Define scope through a 12-asset inventory.
- Identify 15 risk scenarios using likelihood, impact, inherent risk, existing controls, and residual risk.
- Map 15 controls to risk, asset, evidence, owner, frequency, and public framework concepts.
- Assess design, implementation, operating effectiveness, and evidence status using simulated test procedures.
- Translate findings into 15 POA&M actions and a centralized evidence tracker.
- Validate referential integrity and run management queries in an in-memory SQLite database.

Primary public references

Reference	Official URL
NIST Cybersecurity Framework 2.0	https://www.nist.gov/cyberframework
NIST SP 800-30 Rev. 1	https://csrc.nist.gov/pubs/sp/800/30/r1/final
NIST SP 800-53 Rev. 5	https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final
NIST SP 800-53A Rev. 5	https://csrc.nist.gov/pubs/sp/800/53/a/r5/final
ISO/IEC 27001:2022 public overview	https://www.iso.org/standard/27001
CIS Critical Security Controls v8.1	https://www.cisecurity.org/controls
ISACA COBIT resources	https://www.isaca.org/resources/cobit
Indonesia Law No. 27 of 2022 on Personal Data Protection	https://peraturan.bpk.go.id/Details/229798/uu-no-27-tahun-2022

Important limitation

ISO/IEC 27001 mappings are limited to publicly described ISMS and confidentiality, integrity, availability, and risk-management concepts. The project does not reproduce copyrighted standard text or claim clause-level conformity.